

Regulation Ready Resilience

Bridging DR, Cyber & AI Resiliency, and
Regulatory Compliance

Dave Kliemann
Head of Cloud Risk
IBM Cloud
David.Kliemann@ibm.com



Agenda

- Regulatory Perspective
- Reframing Concentration & Technology Risks
- Architecting Regulation Ready Resilience

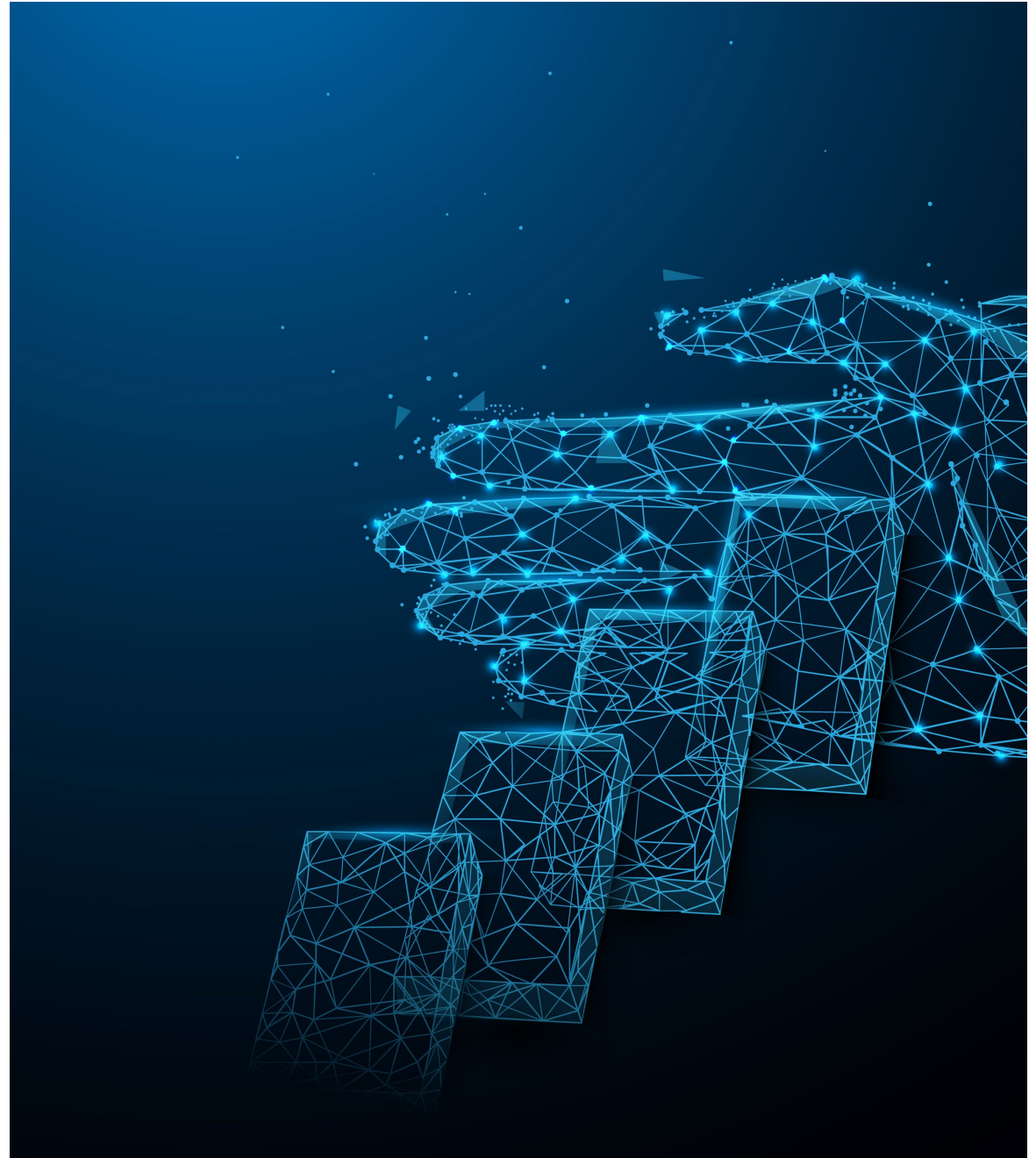
Regulatory Perspective

From compliance to demonstrated resilience

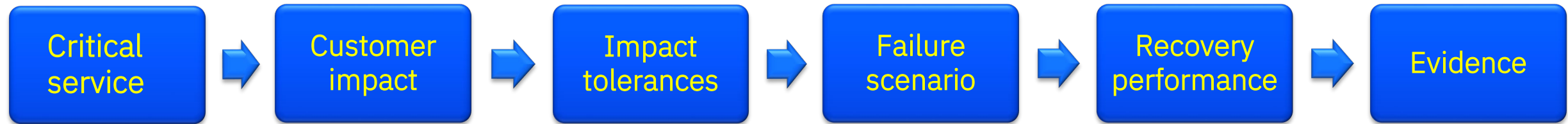
Regulators are shifting from paper compliance to always-on operational resilience.

The test is simple: can critical services continue and recover within tolerances under real stress?

Technology choices need to be positioned and evidenced as an intentional resilience anchor in a regulatory-ready architecture.

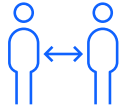


How regulators assess operational resilience



Technical teams often think in terms of:
System → Control → SLA → Component

What we are hearing from the regulators



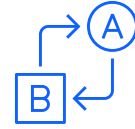
Governance

Roles & Responsibilities

(Bank, Cloud, SaaS, Fintech, MSPs)

3rd/4th Party Risk

(Digital supply chain, SaaS, CSP, Fintech)



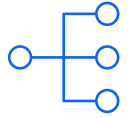
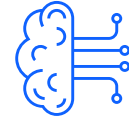
Technology

Operational Resilience

(Technology, cyber & ransomware/ immutable storage)

Hybrid/Multi-Cloud Management

(Strategy, configuration, security, visibility)



Emerging Risk

AI

(Nutrition Label, Model Management)

Concentration Risk

(Workload placement and resiliency strategy; commercial aspects)

Regulatory drivers for stronger Third-Party Risk Management

Cross-Regulatory Themes

- Accountability cannot be outsourced
- Continuous monitoring replaces point-in-time reviews
- Fourth-party and concentration risk in scope



FDIC



Financial Services (OCC, FDIC, FRB)

- Accountability for third parties cannot be delegated
- Enhanced oversight for critical activities
- Lifecycle governance with ongoing monitoring

NERC

Energy & Utilities (NERC CIP-013)

- Mandatory supply-chain cyber risk management plans
- Vendor risk assessments prior to procurement
- Contractual security controls and continuous monitoring



Healthcare (HHS / HIPAA)

- Business Associate Agreements required
- Heightened enforcement tied to vendor failures



EU Financial Services (DORA)

- Mandatory ICT third-party risk strategy
- Prescriptive contracts, exit strategies, and inventories
- Regulatory oversight of critical cloud & ICT providers

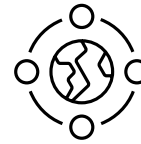
What Regulators Are Really Testing



Shared understanding of critical services



Predictability under degradation



Confidence grounded in tested reality

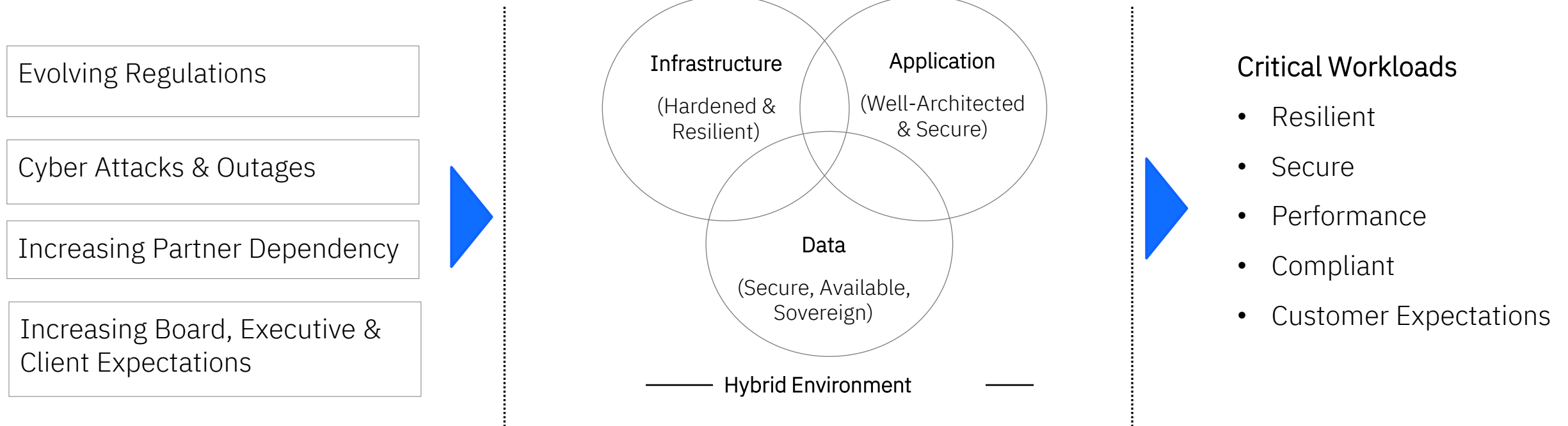
Not just optimism



Reframing concentration & technology dependency risk

Operational Resilience

The ability to continue providing critical business services through disruption of any kind



- Design critical services for operational resilience
- Prioritize fast failover rather than traditional disaster recovery
- Test extensively & learn continuously from scenarios of disruption



Concentration $\neq$ Fragility

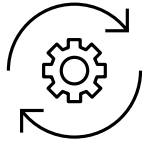
- Unexamined assumptions create risk
- Diffuse architectures can fail harder
- Known behavior builds trust

What Regulators Want to Hear



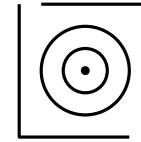
Failure modes understood

- What fails first
- What degrades
- What never should



Changed testing approach

- Not point-in-time-proof, continuous capabilities
- Observed behavior over documented theory
- Confidence earned through exposure, with realism



Credible results

- How the service degrades
- Which workloads isolate impact
- Which paths have been exercised



Architecting Regulation Ready Resilience

Approach: Consistently define, implement & assess controls across hybrid cloud

Security & Compliance management across hybrid multi-cloud

Define



controls based on risk and regulatory requirements

Chief Security Officer /
Chief Risk Officer

Implement



controls consistently across hybrid cloud. Automate.

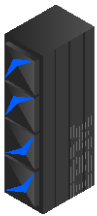
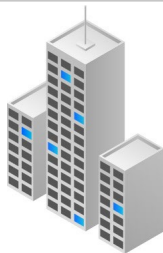
Chief Information Office /
IT & Application Teams

Assess

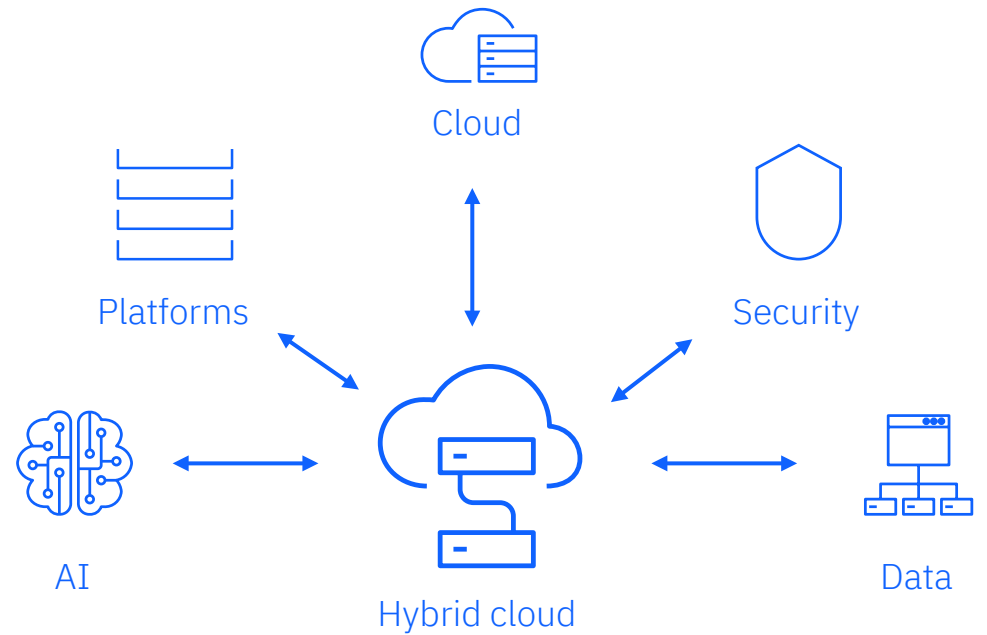


security and compliance posture. Remediate. Get ready for audit.

Chief Compliance Officer /
Chief Security Officer



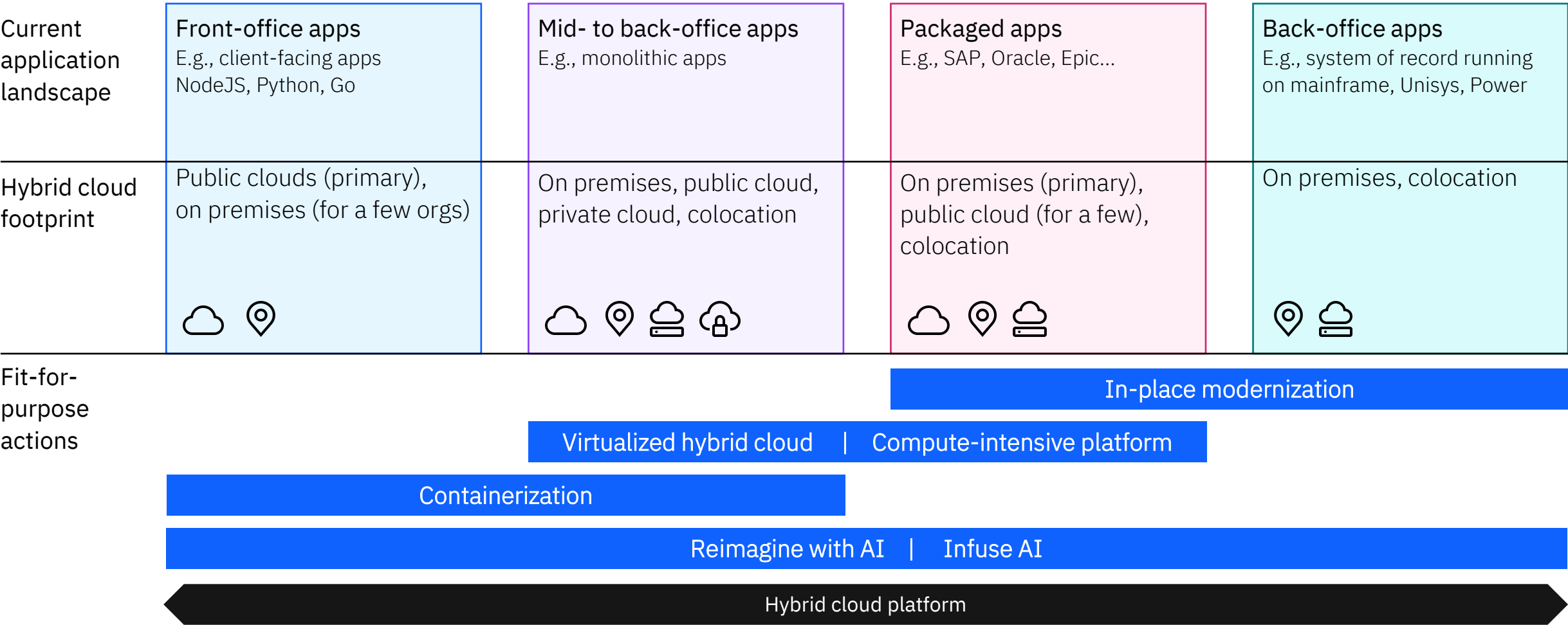
Hybrid by design is a tested, codified architectural framework, running on hybrid cloud, to help organizations optimize business value through technology.



Where Critical Workloads Actually Run

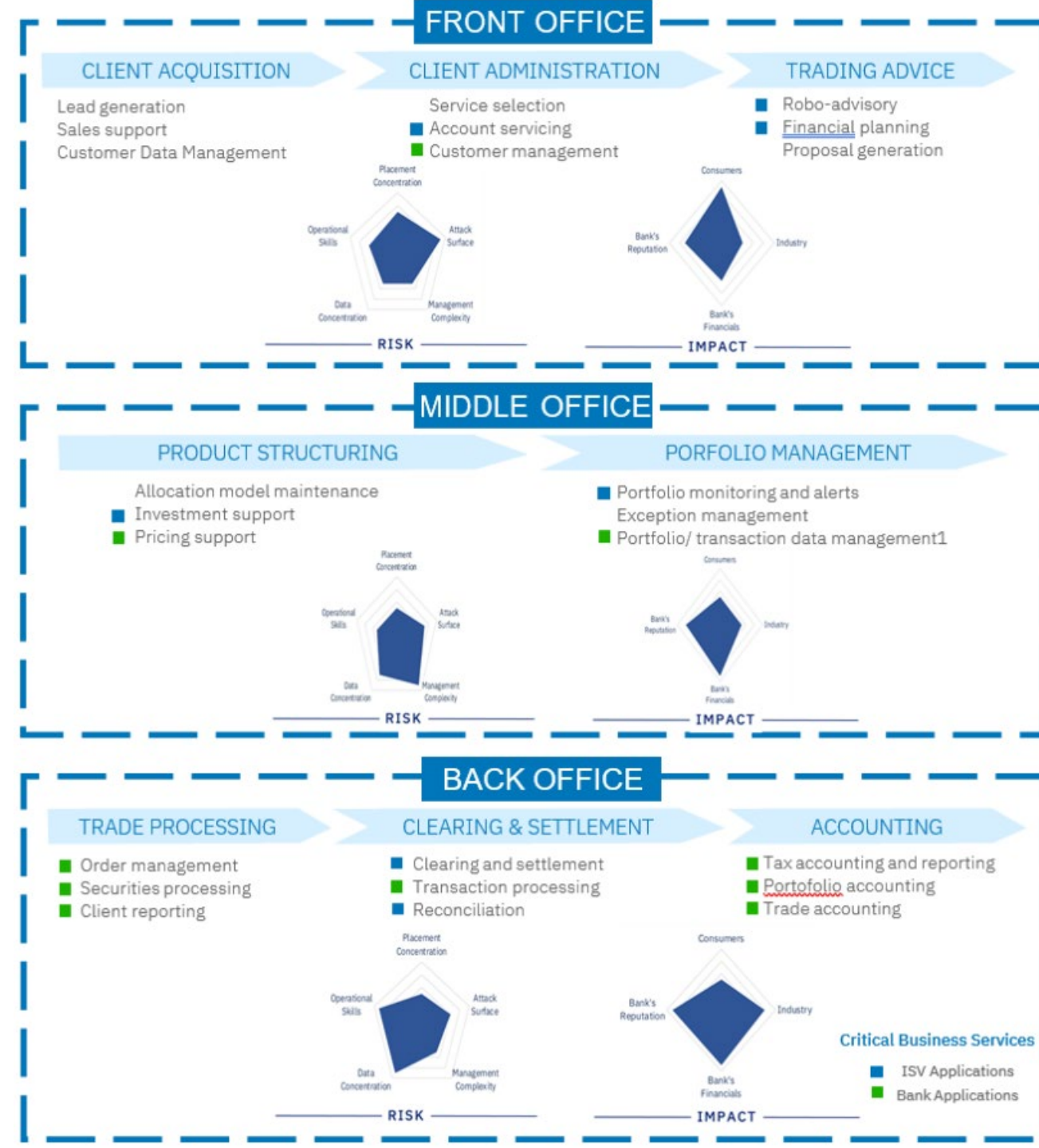
Current application landscape	Front-office apps E.g., client-facing apps NodeJS, Python, Go	Mid- to back-office apps E.g., monolithic apps	Packaged apps E.g., SAP, Oracle, Epic...	Back-office apps E.g., system of record running on mainframe, Unisys, Power
Hybrid cloud footprint	Public clouds (primary), on premises (for a few orgs)  	On premises, public cloud, private cloud, colocation    	On premises (primary), public cloud (for a few), colocation   	On premises, colocation  

Match Modernization Strategy to Workload Characteristics



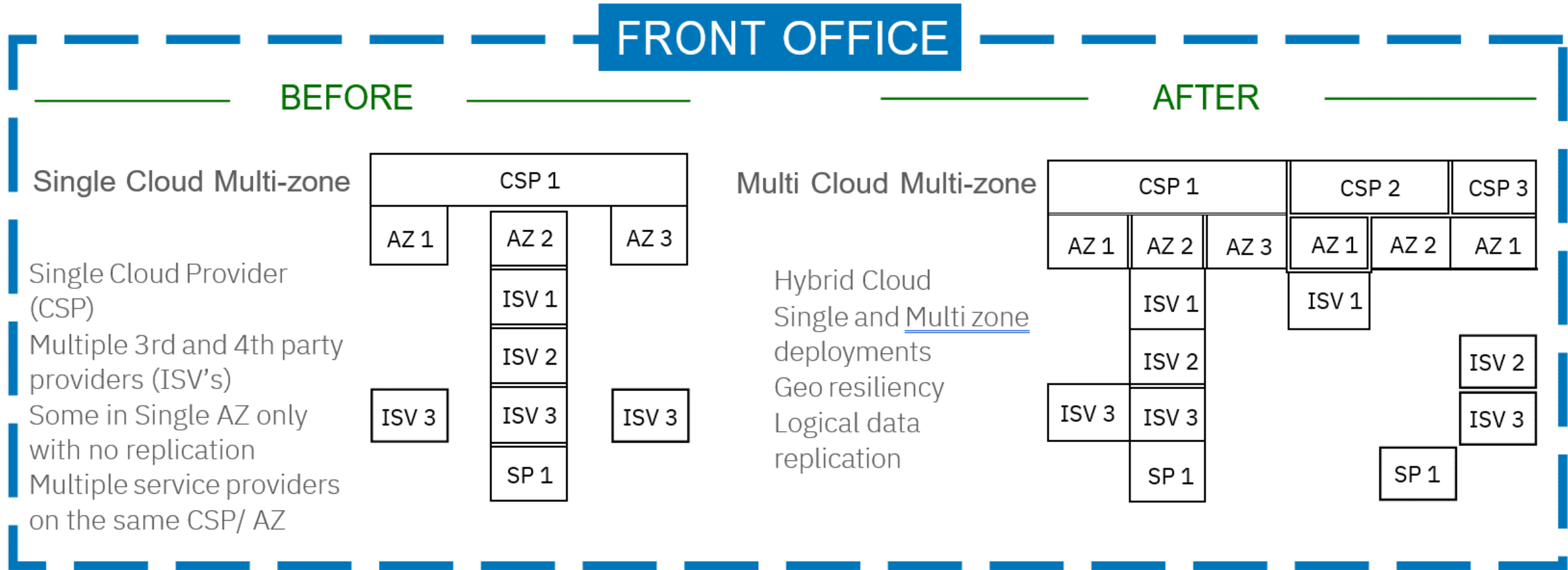
Assess business process risk

- Analyze end-to-end workflow
 - Potential impacts of disruptions
- Applications part of that business service
 - Financial Institution applications
 - Supply chain applications



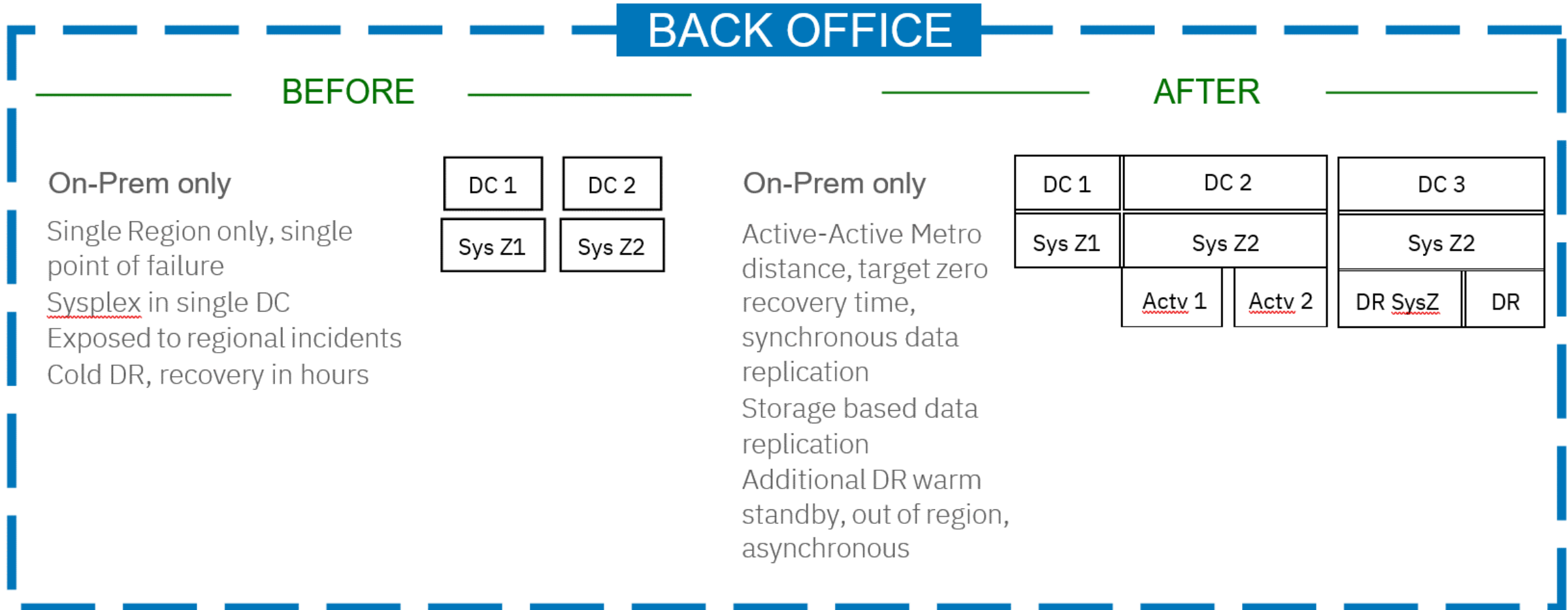
Workload Placement Considerations

Examples of how Workload placement help mitigate concentration risk



Workload Placement Considerations

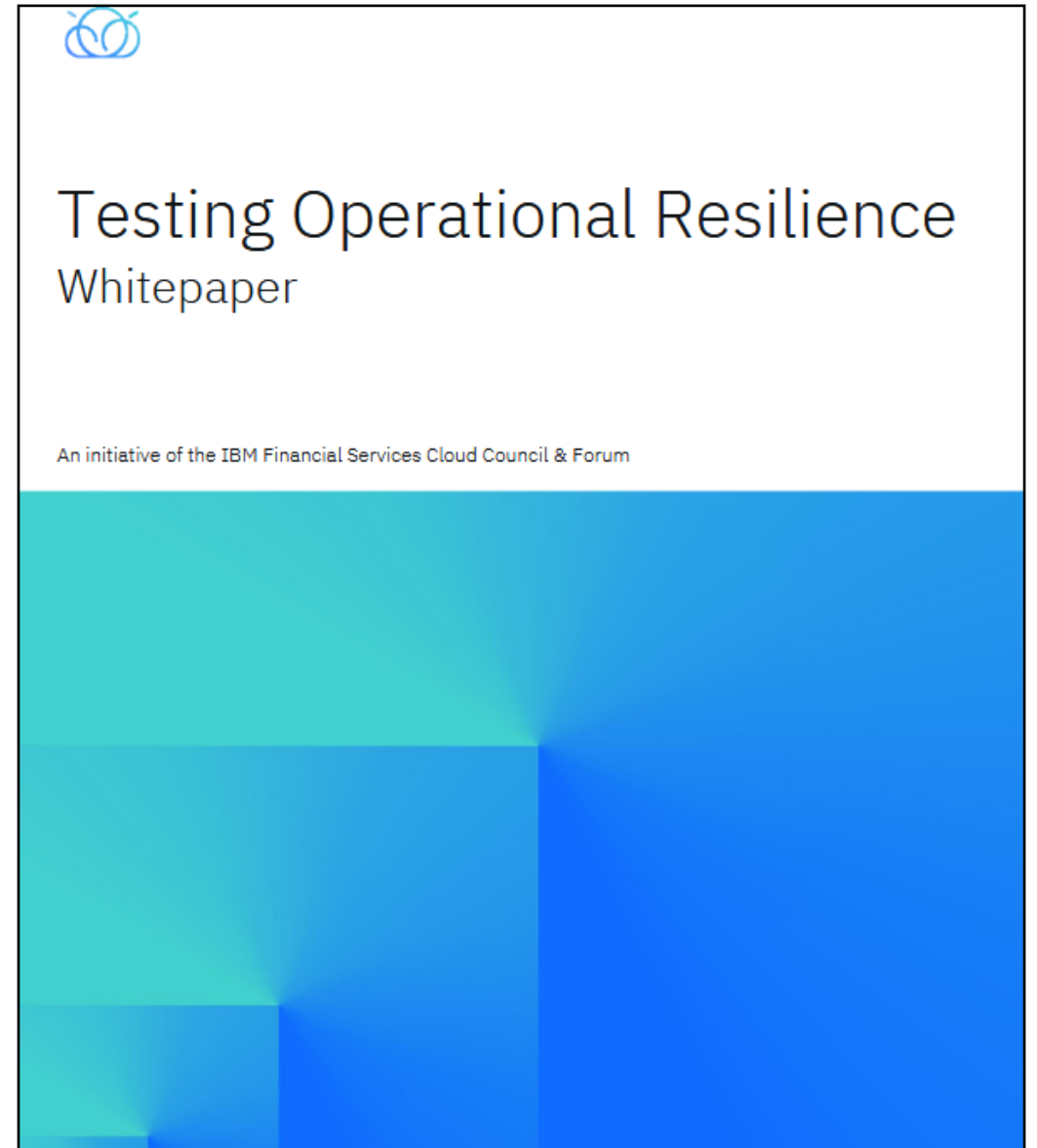
Examples of how Workload placement help mitigate concentration risk

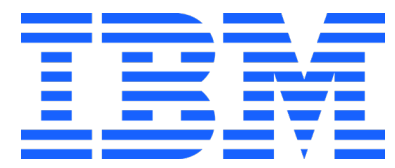


Protect critical systems of record through geographic separation and active-active patterns

Key Takeaways

- Regulators assess outcomes, not controls
- Critical services must be mapped to architecture decisions
- Hybrid Cloud + Mainframe provides resilience when designed intentionally
- Testing creates regulatory confidence





Thank you

© 2026 International Business Machines Corporation

IBM, the IBM logo, IBM Z, Data Gate, Db2, watsonx, z16, z17 and z/OS are trademarks of IBM Corporation, registered in many jurisdictions worldwide. Other product and service names might be trademarks of IBM or other companies. A current list of IBM trademarks is available on <https://www.ibm.com/legal/copyright-trademark>.

This document is distributed “as is” without any warranty, either express or implied. In no event, shall IBM be liable for any damage arising from the use of this information, including but not limited to, loss of data, business interruption, loss of profit or loss of opportunity.

Client examples are presented as illustrations of how those clients have used IBM products and the results they may have achieved. Actual performance, cost, savings or other results in other operating environments may vary.

Not all offerings are available in every country in which IBM operates.

Any statements regarding IBM’s future direction, intent or product plans are subject to change or withdrawal without notice.

All names and references for organizations and other business institutions used in this deliverable’s scenarios are fictional. Any match with real organizations or institutions is coincidental.

All names and associated information for people in this deliverable’s scenarios are fictional. Any match with a real person is coincidental. Videos may show information about or belonging to third parties. Such videos do not suggest endorsement of third parties or their products or services.